

CHECKLIST DE HIGIENE CIBERNÉTICA BÁSICA

NIS2 para PMEs — Conformidade com o DL 125/2025

Esta checklist deve ser revista trimestralmente por cada colaborador e anualmente pelo CISO. É evidência de formação e higiene cibernética para auditoria CNCS. Imprima, assine e arquive — ou use versão digital com registo de data.

Empresa:

Data:

Colaborador:

■ SECÇÃO 1 — PALAVRAS-PASSE E AUTENTICAÇÃO

- ☐

Uso um gestor de palavras-passe para todas as contas de trabalho
Bitwarden Business, 1Password Teams ou equivalente — NUNCA o gestor do browser para contas críticas

OBRIGATÓRIO
- ☐

Cada conta tem uma palavra-passe única e com ≥ 12 caracteres
Não reutilizo a mesma password em diferentes contas — especialmente e-mail + ERP + acesso remoto

OBRIGATÓRIO
- ☐

Tenho MFA (autenticação multifator) ativo em todas as contas de trabalho
Microsoft Authenticator ou Google Authenticator — NÃO por SMS. Verificar: e-mail, VPN, ERP, cloud

OBRIGATÓRIO
- ☐

Não partilho palavras-passe com colegas, mesmo que peçam
Se um colega precisar de acesso, o CISO/TI cria credenciais próprias — partilhar é violação da PSI

OBRIGATÓRIO
- ☐

Bloqueio o ecrã quando me afasto do computador (Win+L / Cmd+Ctrl+Q)
Mínimo: bloqueio automático após 5 minutos de inatividade configurado pelo TI

OBRIGATÓRIO

■ SECÇÃO 2 — E-MAIL E PHISHING

- ☐

Verifico o endereço completo do remetente antes de clicar em qualquer link
Ex: 'support@microsoft.com' (F maiúsculo) ≠ 'support@microsoft.com' — um carácter basta para ser falso

OBRIGATÓRIO
- ☐

Nunca clico em links de e-mails não esperados sem verificar com o remetente
Se recebo um link 'urgente' do banco/fornecedor/colega — ligo a confirmar antes de clicar

OBRIGATÓRIO
- ☐

Nunca abro anexos .exe, .zip, .iso, .js ou .vbs recebidos por e-mail
Estes formatos são vetores de malware frequentes — mesmo que o remetente pareça legítimo

OBRIGATÓRIO
- ☐

Reporto ao CISO/TI qualquer e-mail suspeito (mesmo que não tenha clicado)
Usar o botão 'Reportar Phishing' no Outlook/Gmail — ajuda a proteger toda a empresa

OBRIGATÓRIO
- ☐

Nunca divulgo informações confidenciais ou faço transferências apenas com base n
BEC (Business Email Compromise): verificar SEMPRE por telefone pedidos urgentes de transferência

CRÍTICO — Risco financeiro

■ SECÇÃO 3 — DISPOSITIVOS E DADOS

☐**Uso apenas dispositivos aprovados pela empresa para aceder a sistemas de trabalho**

OBRIGATÓRIO

Não acedo ao e-mail ou ERP da empresa no meu telemóvel pessoal não gerido pelo TI☐**Nunca insiro pendrives ou dispositivos USB desconhecidos no computador**

OBRIGATÓRIO

Pendrives encontradas em espaços públicos são frequentemente armadilhas (técnica 'USB drop')☐**Não instalo software não aprovado pelo departamento de TI**

OBRIGATÓRIO

Inclui: ferramentas gratuitas online, add-ins do browser, apps de produtividade — pedir sempre ao TI☐**Os dados da empresa ficam nos sistemas aprovados (servidor/SharePoint) — não no desktop**

IMPORTANTE

Dados no desktop NÃO são incluídos no backup. Uma avaria significa perda permanente dos ficheiros☐**O meu portátil tem encriptação ativa (BitLocker/FileVault — verificar com TI)**

OBRIGATÓRIO

Se o portátil for roubado sem encriptação, todos os dados ficam expostos ao ladrão

■ SECÇÃO 4 — TRABALHO REMOTO E REDES

☐**Uso sempre VPN quando acedo aos sistemas da empresa fora do escritório**

OBRIGATÓRIO

Nunca acedo ao e-mail ou ERP empresarial por redes Wi-Fi públicas (café, hotel, aeroporto) sem VPN☐**A minha rede Wi-Fi de casa tem uma password forte e encriptação WPA2 ou WPA3**

RECOMENDADO

Verificar nas definições do router — routers com a password padrão são facilmente comprometidos☐**Não uso Wi-Fi público para aceder a sistemas sensíveis — mesmo com VPN, prefiro 4G/5G**

RECOMENDADO

Redes Wi-Fi públicas podem ser interceptadas. 4G/5G pessoal é mais seguro para trabalho sensível☐**Atualizo regularmente o sistema operativo e aplicações no meu portátil de trabalho**

OBRIGATÓRIO

Aceitar atualizações quando o TI notifica — não adiar mais de 48h para atualizações marcadas urgentes

■ SECÇÃO 5 — RESPOSTA A INCIDENTES

☐

Sei como contactar o CISO/TI em caso de incidente (número de emergência memorizado)

CRÍTICO

☐

CISO:

TI Emergência:

Disponível 24h:

☐

Reporto IMEDIATAMENTE qualquer comportamento estranho no computador ao TI

CRÍTICO — Não esperar!

☐

Sintomas: computador lento de repente, ficheiros com extensão estranha, pop-ups de resgate, mouse a mover

☐

Em caso de ransomware: SOLO o computador da rede (desligar cabo/Wi-Fi) e ligo ao TI

CRÍTICO

☐

NÃO desligar o computador — preserva evidências forenses. Apenas isolar da rede é suficiente

☐

Nunca pago um 'resgate' ou forneço dados bancários sem aprovação da gestão e TI

CRÍTICO — Risco financeiro

☐

Todos os pedidos de pagamento urgentes por e-mail devem ser verificados por telefone antes de agir

DECLARAÇÃO DE CONFORMIDADE

Declaro que li, compreendi e me comprometo a cumprir todas as boas práticas de higiene cibernética descritas nesta checklist, conforme a Política de Segurança da Informação da empresa e o DL 125/2025.

Nome:

Data:

Assinatura:

CISO / Responsável:

© NIS2 para PMEs em Portugal

Art. 21.º NIS2 · cncs.gov.pt

Página 3